

ラボ 3.2: Modbus TCP の列挙

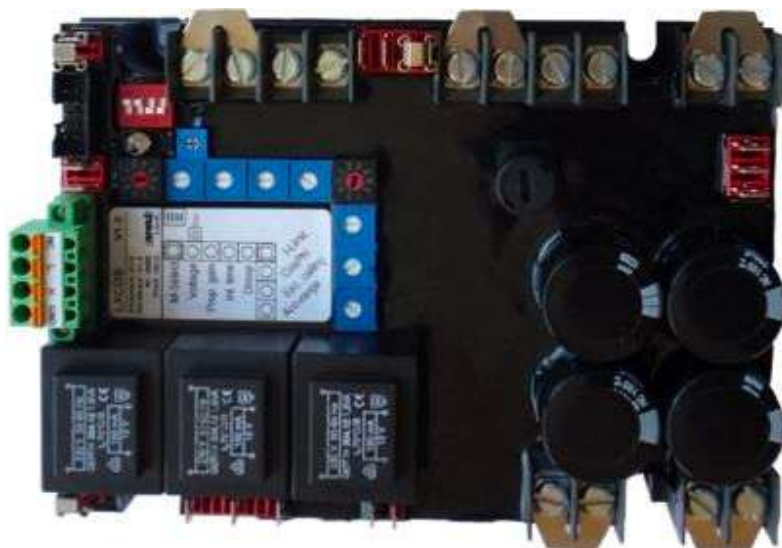
1. はじめに

1.1. 必要なリソース

- ControlThings プラットフォーム VM

1.2. まとめ

このラボでは、Modbus TCPシミュレータを起動して電圧レギュレータをシミュレートします。電圧レギュレータは、可変電圧を入力として受け取り、固定電圧を出力します。Modbusツールを使用して、このシミュレートされた電圧レギュレータと対話し、その値を読み取り、それらの値を変更することでレギュレータを攻撃します



1.3. 目的

- ModbusPalを使用してシミュレートされた電圧レギュレータを作成し、攻撃する
- mbtgetツールの使い方を学ぶ
- シミュレートされた電圧レギュレータからレジスタとコイルを読み取る
- シミュレートされた電圧レギュレータのレジスタとコイルに独自の値を書き込む

2. シミュレーション電圧レギュレータ

ControlThings Platform VMを起動する

Modbus TCP制御プロトコルを使用する電圧レギュレータを作成しました。実行するには、ControlThingsでModbusPalプログラムを起動する必要があります。

ModbusPalを起動する

アクティビティメニューから **ModbusPal** 検索フィールドに入力し、プログラム アイコンをクリックして起動します。

警告

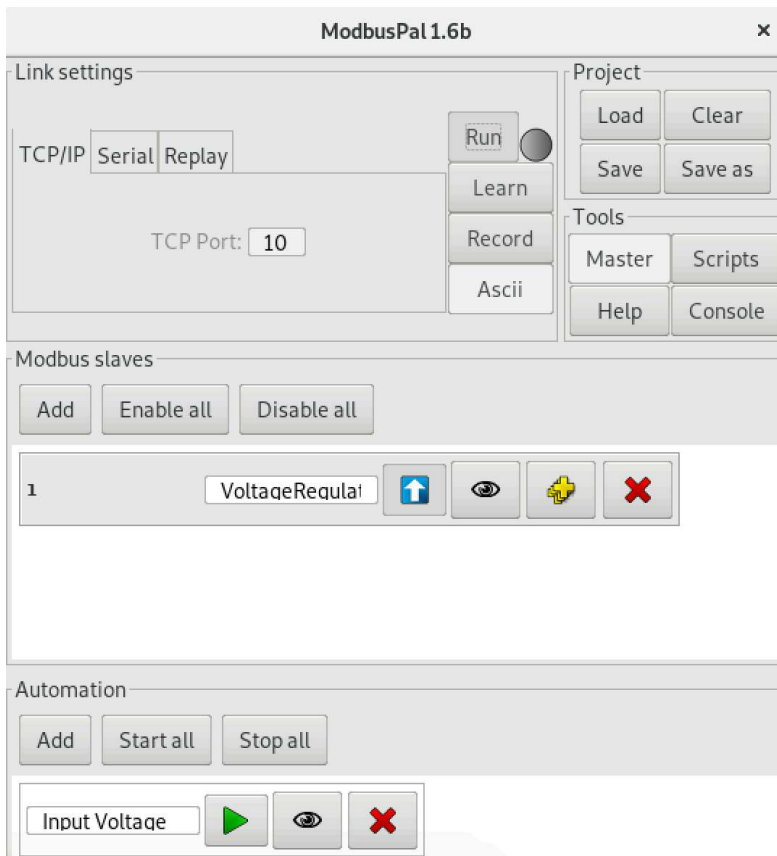
ModbusPalはJavaで書かれたオープンソースアプリケーションで、現在は廃止されています。そのため、古いバージョンのJava JVMで動作することを想定していました。セキュリティ上の理由から、新しいバージョンのJava JVMで動作するように強制していますが、残念ながらアプリケーションに若干のグラフィックの問題が発生しています。無視してください

ModbusPalはModbus TCPおよびModbus RTUプロトコルをシミュレートできます。modbuspalを起動したら、シミュレーションをロードする必要があります。

VoltageRegulator.xmlppファイルをロードする

ModbusPalウィンドウの右上隅にある「ロード」ボタンをクリックすると、**Samples/Simulators/ModbusPal/**フォルダにある**VoltageRegulator.xmlpp**ファイルをロードする必要があります。このファイルをロードしてください。

✓ 成功



電圧レギュレータプロジェクトが読み込まれたら、設定を確認しないでください。これはラボの後半で行います

次に、入力電圧の自動化を開始します。これは、レギュレータの不安定な電圧をシミュレートするものです。シミュレータを実行する前にこれを行います。

入力電圧の自動化を開始する

これを行うには、ウィンドウの下部近くにある「オートメーション」セクションの緑色の三角形の再生ボタンをクリックします。

警告

緑の再生ボタンにマウスオーバーすると、グラフィックが一時的に赤い四角に変わりますが、これはグラフィックの問題です。再生を開始するには緑の再生ボタンをクリックする必要があります。クリックすると赤い四角は消えません

入力電圧の自動化が実行されたら、シミュレータを起動できます。

シミュレータを実行する

ModbusPalウィンドウの上部中央付近に「実行」ボタンがありますので、クリックしてください

成功

実行ボタンの横にある灰色の円は緑色に変わりません。新しいJava JVMではこれも消えてしまいました。**実行**が成功したことを示す唯一の視覚的な指標は、ECPポート番号が薄い灰色に変わることです

ModbusPalの電圧レギュレータは、Modbusが通常使用する標準のTCPポート502ではなく、**TCPポート10502で動作するように設定されています。また、127.0.0.1またはローカルホストアドレスでリッスンするように設定されています。**

3. Modbusクライアント

Modbus TCPプロトコルとやり取りするために、mbtgetというコマンドラインツールを使用します。mbtgetのようなツールを使用すると、攻撃者は実行中のICSプロセスのタグ値を変更するModbusコマンドを簡単に作成できます。これにより、プロセスが停止したり、最悪の場合、物理的な機械に損傷を与えたりする可能性があります。そのため、プロセスエンジニアの明示的な許可なしに、mbtgetのようなツールを本番ネットワークで使用することはお勧めしません。ただし、ControlThings Platform内で使用している仮想環境のようなテストラボ環境がある場合は、テストシステムとやり取りする絶好の機会となります

ターミナルウィンドウを開く

画面の左上隅にある「アクティビティ」リンクをクリックしてメインメニューに移動し、左下にある黒いボックスのような「ターミナル」アイコンをクリックします。

ターミナルが開いたら、**mbtget**の help コマンドを実行して、ツールの使い方を学びましょう。

入力

```
mbtget -h
```

mbtgetの構文と利用可能なオプションのリストが表示されます

✓ 成功

```
usage : mbtget [-hvdsf]
          [-u unit_id] [-a address] [-n number_value]
          [-r[12347]] [-w5 bit_value] [-w6 word_value]
          [-p port] [-t timeout] serveurur

command line :
-h                : show this help message
-v                : show version
-d                : set dump mode (show tx/rx frame in hex)
-s                : set script mode (csv on stdout)
-r1               : read bit(s) (function 1)
-r2               : read bit(s) (function 2)
-r3               : read word(s) (function 3)
-r4               : read word(s) (function 4)
-w5 bit_value     : write a bit (function 5)
-w6 word_value    : write a word (function 6)
-r7               : read exception status
-f                : set floating point value
-hex              : show value in hex (default is decimal)
-u unit_id        : set the modbus "unit id"
-p port_number    : set TCP port (default 502)
-a modbus_address : set modbus address (default 0)
-n value_number   : number of values to read
-t timeout        : set timeout seconds (default is 5s)
```

Modbus TCPは非常にシンプルなプロトコルなので、Modbusコマンドを生成するもう一つの方法として、Netcatのような汎用ツールがあります。NetcatはWindowsとLinuxに対応したツールで、TCPまたはUDP経由のネットワーク接続の読み書きが可能です。Netcat（ncとも呼ばれる）は、ポートスキャン、ポートフォワーディング、ポートリスニング、システムへのバックドアなど、様々な用途に使用できます。

Modbusで通信する際は、常にアドレス（-a）と、各種の読み取りまたは書き込みコマンドのいずれかを指定します。Modbusデバイスに複数のスレーブまたはユニットIDがある場合は、それも指定する必要があります（-u）。ただし、今回の場合、VoltageRegulatorにはユニットIDが0のみで、これはデフォルトで暗黙的に設定されます。

4. Modbusの列挙

ここで、電圧レギュレータがより大きなICSの一部であり、このModbusプロトコルを介してPLCによって監視および制御されていると仮定しましょう。私たちは攻撃者の役割を演じ、Modbus TCPを介してこのデバイスに直接通信しようとしています。まず最初

に、レジスタとコイルの読み取りを試みます

最初の 5 つの保持レジスタ (アナログ出力) を読み取るための読み取り要求を送信してみます。

入力

```
mbtget -r3 -a 0 -n 5 -p 10502 127.0.0.1
```

上記のコマンドでは、スペースを入れるべき場所と入れるべきでない場所に注意してください

✖ サーバー接続 [127.0.0.1]:10502 失敗

サーバー接続「127.0.0.1:10502」失敗応答を受け取った場合は、ModbusPal で**実行**ボタンをクリックしたかどうかを確認してください。

✔ 成功

values:

```
1 (ad 00000): 116
2 (ad 00001): 120
3 (ad 00002): 110
4 (ad 00003): 130
5 (ad 00004): 0
```

各アドレスの値は、ここに表示されているものと異なる場合があります。

失敗

最初のアドレスの値が**0**の場合は、ModbusPalウィンドウに戻り、**自動化セクションの緑色の三角形**の再生ボタンをクリックします。

Modbusはタグ名を取得せず、要求したアドレス番号のみを取得する点に注目してください。ほとんどのICSプロトコルと同様に、Modbusはプロトコル内でタグ名を使用する機能がありません。特定のタグを要求したい場合は、エンジニアまたはベンダーがそのタグのModbusアドレスをどのように設定しているかを知っておく必要があります。

このコマンドをさらに数回実行して、どのアドレスが変更され、その値がどの程度変更されているかを確認してください。

表示されている値に基づいて、それぞれの値は何を表していると考えられますか？

i ICSプロトコルとアドレス

`mbtget`の出力では、各行に2つの異なるアドレスがあることに注意してください。

```
1 (ad 00000): 116
```

コマンドで最初に要求したアドレスは0番地で、これは括弧内の**00000番地**に対応します。では、なぜ先頭に**1**があるのでしょうか？

多くのベンダーの設定インターフェースは、人間にとって分かりやすいようにModbusアドレスを1から開始します。しかし、Modbus TCPプロトコルはアドレス番号を0から開始します。そのため、Modbusユーザーインターフェースと生のModbusトラフィックの間に一時的な問題が発生します。Modbusトラフィックを扱う際は、必ずソリューションにこの一時的な問題が発生していないか確認してください。

ちなみに、これは他のICSプロトコル、特に古いプロトコルでも一般的です。'''

ここで、最初の5つのコイル(デジタル出力)を読み取るための読み取り要求を送信してみます。

入力

```
mbtget -r1 -a 0 -n 5 -p 10502 127.0.0.1
```

✓ 成功

values:

```
1 (ad 00000): 1
2 (ad 00001): 0
3 (ad 00002): 0
4 (ad 00003): 0
5 (ad 00004): 0
```

このコマンドをさらに数回実行します。

これらの新しい値に基づいて、それぞれの値は何を表していると思いますか？

各レジスタとコイルが何を表すのかを明記したデバイスのドキュメントがない場合、それぞれの値の意味を推測するしかありません。レジスタのようなケースではある程度推測できますが、コイルのようなデジタル値や離散値の場合はほぼ不可能です。そのため、攻撃者はデバイスのドキュメントやベンダーの設定ツールを探し、それぞれの値の意味を特定しようとします。もちろん、これは攻撃者が何らかの戦略的な行動を起こそうとしていることを前提としています。もし攻撃者の唯一の目的が損害を与えることであれば、すべての値をランダムに変更するだけで済みますが、それは壊滅的な被害をもたらす可能性があります。

5. ModbusPalの設定

これは電圧レギュレータであることをご存知なので、特に北米の120Vシステムで動作するように設定されていると言えば、これらのレジスタとコイルが何であるかについてある程度推測できます。電圧レギュレータは、大きく変動する入力電圧を受け取り、それを安定した出力電圧に固定します。これらの5つのレジスタと5つのコイルは何をしたいと思いますか？レジスタ0と1は比較的簡単に理解できますが、レジスタ2と3は少し難しく、レジスタ4は判別不可能です。もちろん、ModbusPalではアドレスが1から始まるのに対し、実際のプロトコルではアドレスが0から始まるため、これらのアドレスにそれぞれ1を追加する必要があります。これは、Modbusや多くの古いICSプロトコルでは普通のことです。コイルに関しては、2つの選択肢しかないため、すべて判別不可能です

ちょっと手抜きして ModbusPal の構成を確認してみましょう。

ModbusPalの電圧レギュレータ設定を開く

Modbusスレーブセクションで、スレーブ1の横にある目のアイコンをクリックしてください。この最初の画面では、ツールが孤立しており、テキストフィールドが読みにくいので、改めてお詫び申し上げます。目のアイコンをクリックすると、いくつかのタブを含む新しいウィンドウが表示されます。「Holding registers（保持レジスタ）」と「Coils（コイル）」タブの下に、各レジスタとコイルのタグ名と値が表示されます。

✓ 成功

Address	Value	Name	Binding
1	117	InputVolt...	Input Vol...
2	120	OutputV...	
3	110	MinOupu...	
4	130	MaxOutp...	
5	0		
6	0		
7	0		
8	0		
9	0		
10	0		
11	0		
12	0		
13	0		

6. Modbus書き込み

Modbus TCPは認証オプションをサポートしていないため、レジスタとコイルの値を読み取るのと同じくらい簡単に変更できます。電圧を欧州レベルに変更し、電圧アラームを無効にしてみましょう

ModbusPal 構成のレジスタ 2 であるレジスタ 1 の現在の値を確認します。

入力

```
mbtget -r3 -a 1 -p 10502 127.0.0.1
```

これは120に設定する必要があります。

レジスタ1に新しい値を書き込んでみます

入力

```
mbtget -w6 240 -a 1 -p 10502 127.0.0.1
```

もう一度読んで変更があったかどうか確認してみましょう。

入力

```
mbtget -r3 -a 1 -p 10502 127.0.0.1
```

出力電圧は 240 に設定されるはずです。VoltageRegulator の目をクリックして、レジスタ 2 の値が変化することを確認できます (1 回限りの問題に注意してください)。

次に、電圧アラームを無効にします。

ModbusPal 構成ではコイル 2 であるコイル 1 の現在の値を確認します。

入力

```
mbtget -r1 -a 1 -p 10502 127.0.0.1
```

これは依然として 0 に設定されている必要があります。

コイル 1 に新しい値を書き込もうとします。

入力

```
mbtget -w5 1 -a 1 -p 10502 127.0.0.1
```

もう一度読んで変更があったかどうか確認してみましょう。

入力

```
mbtget -r1 -a 1 -p 10502 127.0.0.1
```

それで大丈夫でしょう。授業で本物の電圧レギュレータを使ってこれをやって、電圧レギュレータに接続された機器から魔法の煙が上がるのを見られないのは、嬉しいのか悲しいのかよく分かりません...

では、これは現実世界におけるリスクとどのように関連しているのでしょうか？攻撃者が各レジスタとコイルが何を表しているのかを解明できれば、システムに最大の損害を与えるための戦略的なシナリオを作成できます。例えば、攻撃者は安全オーバーライドシステムを作動させ、電圧レギュレータの出力を変更することで、電圧レギュレータから電力供給を受けているデバイスに損害を与える可能性があります。これは非常に単純ですが、イランの核施設で確認されたStuxnetのペイロードに類似しています。

7. ボーナスチャレンジ

他の参加者のラボの完了を待っている場合、またはこのラボで紹介された概念をさらに深く探求したい場合は、いくつかのアイデアを試してみてください。これらのチャレンジにはチュートリアルは用意されていませんが、行き詰まった場合は、コース作成者のジャスティンに取り組みの過程を見せていただければ、喜んでヒントをくれるでしょう。justin [@controlthings.io](mailto:justin@controlthings.io)までメールでお問い合わせください

7.1. Modbus と Netcat

Modbus TCPは非常にシンプルなプロトコルなので、Modbusコマンドを生成するもう一つの方法として、Netcatのような汎用ツールがあります。NetcatはWindowsとLinuxに対応したツールで、TCPまたはUDP経由のネットワーク接続の読み書きが可能です。Netcat（ncとも呼ばれる）は、ポートスキャン、ポートフォワーディング、ポートリスニング、システムへのバックドアなど、様々な用途に使用できます。

mbtgetの-dオプションを使用して、送信する正確なTX文字列を取得します。

echoの-eオプションを16進値で使用方法を学びます

netcatの使い方を学ぶ